

HabitFlow API Specification

Team-404

Version 1.1

Last Updated: 2026, Sept. 30

Prepared by: Eunice Grace O. Revillas (Authentication API Spec)

Endpoints marked with an Authorization parameter require the header Authorization: Bearer <token> from /api/auth/login. Every authenticated request only sees data owned by that user.

I. Authentication (api/auth)

A. User Signup

API Endpoint	/api/auth/signup	
method	POST	
Request Parameters	Type	Description
username	string	Unique username (max 50 chars).
email	string	Unique email address (max 255 chars).
password	string	User password (min 8 chars), stored as password_hash.
timezone	string	Optional IANA timezone (default is Asia/Manila).
Creates a new user account and its Inbox project. The Inbox is the default project for tasks created without a projectId.		
Success		
Status Code	200	
Response Type	json	
Response Data	Type	Description
message	string	Registration success message.
userId	integer	Unique ID of the new user.
username	string	Registered username.
email	string	Registered email address.
inboxProjectId	integer	ID of the Inbox project created for the user.
Sample Response		
{ "message": "User registered successfully", "userId": 101, "username": "habitUser", "email": "user@example.com", "inboxProjectId": 1 }		
Fail		
Status Code	400	
Response Type	json	
Response Data	Type	Description

error	string	Reason registration failed.
Sample Response		
{"error": "Username or email already exists"}		

B. User Login / Verify Credentials

API Endpoint	/api/auth/login	
method	POST	
Request Parameters	Type	Description
email	string	Registered user email.
password	string	User password.
<i>Verifies user credentials, creates an authenticated session token and updates last_login_at. Deactivated or deleted accounts cannot log in.</i>		
Success		
Status Code	200	
Response Type	json	
Response Data	Type	Description
token	string	Bearer authentication token.
user	object	Authenticated user details.
user.id	integer	User ID.
user.username	string	Username.
user.email	string	Email address.
user.timezone	string	User timezone.
Sample Response		
{"token": "eyJhbGciOiJIUzI1Ni...", "user": {"id": 1, "username": "habitBuilder123", "email": "user@example.com", "timezone": "Asia/Manila"}}		
Fail		
Status Code	401	
Response Type	json	
Response Data	Type	Description
error	string	Authentication failure message.
Sample Response		
{"error": "Invalid email or password"}		

C. Check Username

API Endpoint	/api/auth/check-username/{username}
method	GET

Request Parameters	Type	Description
username	string	Username to check (path parameter).
<i>Checks if a username is already taken. Used by the signup form before submitting.</i>		
Success		
Status Code	200	
Response Type	json	
Response Data	Type	Description
available	boolean	True if the username is available, false otherwise.
username	string	The username that was checked.
Sample Response		
{"available": true, "username": "habitUser"}		
Fail		
Status Code	400	
Response Type	json	
Response Data	Type	Description
error	string	Reason for invalid request (e.g., length violation).
Sample Response		
{"error": "Username must be at most 50 characters"}		

D. Check Email

API Endpoint	/api/auth/check-email/{email}	
method	GET	
Request Parameters	Type	Description
email	string	Email to check (path parameter).
<i>Checks if an email is already registered. Used by the signup form before submitting.</i>		
Success		
Status Code	200	
Response Type	json	
Response Data	Type	Description
available	boolean	True if the email is available, false otherwise.
email	string	The email that was checked.
Sample Response		
{"available": false, "email": "user@example.com"}		
Fail		

Status Code	400	
Response Type	json	
Response Data	Type	Description
error	string	Reason for invalid request (e.g., invalid format).
Sample Response		
<pre>{"error": "Invalid email format"}</pre>		

E. Get Current User

API Endpoint	/api/auth/me	
method	GET	
Request Parameters	Type	Description
Authorization	string	Bearer token of the authenticated user.
<i>Returns the authenticated user's details. Used to restore the session when the app is reopened.</i>		
Success		
Status Code	200	
Response Type	json	
Response Data	Type	Description
id	integer	User ID.
username	string	Username.
email	string	Email address.
timezone	string	User timezone.
inboxProjectId	integer	ID of the user's Inbox project.
Sample Response		
<pre>{"id": 1, "username": "habitBuilder123", "email": "user@example.com", "timezone": "Asia/Manila", "inboxProjectId": 1}</pre>		
Fail		
Status Code	401	
Response Type	json	
Response Data	Type	Description
error	string	Token missing, invalid or expired.
Sample Response		
<pre>{"error": "Token invalid or expired"}</pre>		

F. Update Profile

API Endpoint	/api/auth/me	
method	PUT	

Request Parameters	Type	Description
Authorization	string	Bearer token of the authenticated user.
username	string	Optional. New unique username (max 50 chars).
timezone	string	Optional. New IANA timezone. Scheduling status is recomputed in this timezone.
<i>Updates the authenticated user's username or timezone. Fields not sent are left unchanged.</i>		
Success		
Status Code	200	
Response Type	json	
Response Data	Type	Description
id	integer	User ID.
username	string	Username.
timezone	string	User timezone.
message	string	Success confirmation.
Sample Response		
<pre>{"id": 1, "username": "habitBuilder123", "timezone": "Asia/Manila", "message": "Profile updated successfully"}</pre>		
Fail		
Status Code	400	
Response Type	json	
Response Data	Type	Description
error	string	Validation error.
Sample Response		
<pre>{"error": "Username already exists"}</pre>		
Fail		
Status Code	401	
Response Type	json	
Response Data	Type	Description
error	string	Authentication error.
Sample Response		
<pre>{"error": "Unauthorized"}</pre>		

G. User Logout

API Endpoint	/api/auth/logout
method	POST

Request Parameters	Type	Description
Authorization	string	Bearer token of the authenticated user.
<i>Ends the authenticated session and invalidates the current token.</i>		
Success		
Status Code	200	
Response Type	json	
Response Data	Type	Description
message	string	Logout confirmation.
Sample Response		
{ "message": "Logged out successfully" }		
Fail		
Status Code	401	
Response Type	json	
Response Data	Type	Description
error	string	Authentication error.
Sample Response		
{ "error": "Unauthorized" }		

H. Forgot Password

API Endpoint	/api/auth/forgot-password	
method	POST	
Request Parameters	Type	Description
email	string	Registered email address.
<i>Starts password recovery. Creates a tbl_password_reset record (token stored as token_hash, valid for 1 hour) and emails a reset link. The response is the same whether or not the email exists.</i>		
Success		
Status Code	200	
Response Type	json	
Response Data	Type	Description
message	string	Confirmation that the process has started.
Sample Response		
{ "message": "If that email exists, a reset link has been sent." }		
Fail		
Status Code	400	
Response Type	json	
Response Data	Type	Description

error	string	Reason for invalid request.
Sample Response		
{"error": "Invalid email address provided"}		

I. Validate Reset Token

API Endpoint	/api/auth/validate-reset-token	
method	GET	
Request Parameters	Type	Description
token	string	Reset token from the emailed link (query parameter).
<i>Checks that a reset token exists, has not expired and has not been used. Used by the reset password page before showing the form.</i>		
Success		
Status Code	200	
Response Type	json	
Response Data	Type	Description
valid	boolean	True if the token can be used.
Sample Response		
{"valid": true}		
Fail		
Status Code	400	
Response Type	json	
Response Data	Type	Description
valid	boolean	False if the token cannot be used.
error	string	Reason (expired, used or invalid).
Sample Response		
{"valid": false, "error": "Token expired"}		

J. Reset Password

API Endpoint	/api/auth/reset-password	
method	POST	
Request Parameters	Type	Description
token	string	Valid reset token.
newPassword	string	New password (min 8 chars).
confirmPassword	string	Must match newPassword.

Sets a new password and marks the reset token as used (used_at). Existing session tokens are invalidated.

Success

Status Code	200	
Response Type	json	
Response Data	Type	Description
message	string	Confirmation of successful password reset.

Sample Response

```
{"message": "Password has been reset successfully"}
```

Fail

Status Code	400	
Response Type	json	
Response Data	Type	Description
error	string	Reason for failure.

Sample Response

```
{"error": "Passwords do not match"}
```